

# Why AI Governance Must Be Enforced, Not Assumed

Executive Brief for CISO, Compliance, Risk, and AI Governance Leaders

## Executive Summary

AI governance is not established by maintaining policy documents. Policy defines intent, but it does not prove that an AI-assisted action was reviewed, authorized, traceable, or blocked when required evidence was missing.

Enterprise governance must operate at runtime. Before execution, the control environment should validate policy state, approval state, provenance, and audit evidence. If those controls cannot be verified, the action should be denied and the denial should be preserved as evidence.

## Governance Requires Runtime Enforcement

Documentation alone cannot show whether a control actually operated at the moment of decision. Runtime enforcement closes that gap by evaluating governance requirements before an AI-assisted action is allowed to proceed.

A runtime control should answer four questions: which policy applies, who approved the action, what evidence supports the decision, and whether the action was allowed or blocked. The absence of reliable evidence is itself a control failure.

## Human Oversight Must Produce Evidence

Human oversight should create a durable decision record. For high-risk workflows, the record should identify the reviewer, the decision, the timestamp, the scope of approval, and the policy context that governed the review.

This evidence is necessary for security, compliance, legal, risk, and audit teams that must verify that human judgment was applied before execution, not inferred after the fact.

## Minimum Control Expectations

The following controls define the minimum evidence expectations for governed AI execution.

| Human Oversight |                                                                                            |
|-----------------|--------------------------------------------------------------------------------------------|
| Requirement     | Explicit review for high-risk actions before execution.                                    |
| Evidence        | Reviewer identity, decision, timestamp, approval scope, and policy context.                |
| Audit Evidence  |                                                                                            |
| Requirement     | A reconstructable record for every allow or deny decision.                                 |
| Evidence        | Actor, policy version, validation result, approval state, and execution outcome.           |
| Provenance      |                                                                                            |
| Requirement     | Traceability across inputs, workflow context, and decision path.                           |
| Evidence        | Source references, workflow lineage, model or automation context, and evidence references. |

| Fail-Closed Controls |                                                                                       |
|----------------------|---------------------------------------------------------------------------------------|
| Requirement          | Blocking behavior when validation evidence is missing or incomplete.                  |
| Evidence             | Denial reason, missing-control indicator, blocked outcome, and preserved audit trail. |

## Audit Evidence And Provenance

Audit evidence should be generated as part of the decision path. It should show the actor, policy version, validation result, approval state, provenance, and execution outcome for each allow or deny decision.

Provenance should preserve the lineage of inputs, workflow context, model or automation context, and evidence references. Without provenance, the organization may be unable to reconstruct why an AI-assisted action occurred or why it was blocked.

## Fail-Closed Control Position

Governed AI workflows should treat unknown state as unsafe state. Missing approval, incomplete provenance, unavailable policy validation, or absent audit evidence should block execution.

Fail-closed behavior is not a user-experience preference. It is a control requirement for enterprise environments where unverifiable execution can create compliance, security, legal, and operational risk.

## Executive Takeaway

The central governance question is not whether an AI system can produce an output. The enterprise question is whether the resulting action is authorized, policy-compliant, attributable, traceable, and defensible.

Governance that cannot enforce decisions at runtime remains an assumption. Governance that validates evidence before execution becomes a control.